

课程讲义

Misaligned: AI Jailbreaking Panel by Basi Team Six & Jason Haddix

sss & Codex

2026-06-11



来源频道: Bug Bounty DEFCON

发布日期: 2026-06-01

视频时长: 01:00:27

视频链接: <https://www.youtube.com/watch?v=yxqGAtUR8fY>

制作说明: 本讲义基于英文字幕、视频画面和抽帧复核整理, 面向防御学习、漏洞赏金治理和 AI 安全工程实践。

目录

1 术语与符号表	4
1.1 阅读地图	5
2 导读：一场关于“失准 AI”的安全圆桌	5
2.1 本片的主线	6
2.2 本章小结	6
3 为什么大厂内部红队仍会漏掉越狱	6
3.1 潜在空间与覆盖鸿沟	7
3.2 团队协作为什么有效	7
3.3 本章小结	7
4 从复制型提示到语境层叠：越狱范式的演化	8
4.1 洋葱层模型	8
4.2 防御方应该怎样读这个变化	8
4.3 本章小结	9
5 AI 攻击 AI：人机协同、侦察、模糊测试与评分	9
5.1 从种子到评分的循环	9
5.2 触发词、变体与非确定性	9
5.3 本章小结	10
6 慢燃式上下文操控与信任感错觉	10
6.1 上下文窗口如何改变判断	10
6.2 从模型信任到系统可信	11
6.3 本章小结	11
7 多模态越狱：输入输出视角下的安全护栏差异	11
7.1 多模态模型与生成式 AI	11
7.2 模型卡、迭代测试与社区笔记	12
7.3 本章小结	13
8 会搭护栏的人更会拆护栏：情绪、低 token、一次性攻击	13
8.1 从情绪分析理解分类器的盲区	13
8.2 低 token 输入与 one-shot 的复现诱惑	14

8.3 本章小结	14
9 漏洞赏金、POC 与“为什么总用危险输出做标尺”	14
9.1 AI 赏金和传统赏金的差异	15
9.2 危险输出为何会成为公共标尺	15
9.3 本章小结	16
10 护栏像 WAF 吗：持续测试、供应链与新安全范式	17
10.1 WAF 类比的价值和边界	17
10.2 从打补丁转向新范式	17
10.3 本章小结	18
11 团队结构与攻防非对称：AI 对攻击者和防御者的杠杆	18
11.1 开放社区、私有协作与披露边界	19
11.2 攻击者优势与防御者负担	19
11.3 本章小结	20
12 AI 红队的系统视角：从模型到 ML SecOps 全链路	20
12.1 为什么“测模型”覆盖不足	20
12.2 系统攻击面公式	20
12.3 从红队报告到 ML SecOps	21
12.4 本章小结	21
13 不舒服的事实：提示注入、能力增长与攻击面扩张	21
13.1 “完全解决”这个承诺为什么危险	21
13.2 能力增长会把今天的小漏洞放大	22
13.3 攻击面与工具能力的比例关系	22
13.4 本章小结	23
14 Q&A：有用性与控制性、语义攻击、低资源语言与多样化红队	24
14.1 有用性与控制性的拉扯	24
14.2 语义、认识论与本体论攻击	25
14.3 低资源语言、代码通道与分类器盲区	25
14.4 为什么多样化红队有效	26
14.5 本章小结	27

15 Q&A：首次越狱体验、智能体工具、复现与现场演示	27
15.1 首次突破的心理类比	27
15.2 智能体安全设计：把 LLM 当成不可信调用者	28
15.3 非确定性 POC 与幻觉辨别	29
15.4 现场演示：风险链与控制点	29
15.5 本章小结	31
16 总结：从“让模型拒绝”走向“让系统承受失败”	31
16.1 结尾讨论：危险输出验证的尴尬问题	31
16.2 全片的风险压缩	32
16.3 防御路线图	32
16.4 本章小结	33
A 资料来源与制作说明	33

1 术语与符号表

这一节先固定术语，避免后文把模型行为、应用边界和组织治理混成一团。AI 安全里的同一个现象常常同时属于“模型拒答失败”“应用权限过宽”和“披露流程失灵”，术语表相当于读图例。

英文术语	中文译法	本讲义中的含义
AI jailbreak	AI 越狱	通过上下文、格式、角色、模态或多轮状态诱导模型越过预期安全边界。
Prompt injection	提示注入	外部内容影响模型指令层级或工具决策，使系统偏离开发者意图。
Guardrails	安全护栏	输入过滤、系统提示、输出分类器、日志审计、人工复核等约束组合。
Safety classifier	安全分类器	对输入或输出估计风险的模型或规则系统，可抽象为 $p(\text{harm} \mid x)$ 。
Latent space	潜在空间	模型内部表征的语义空间；相近含义可能在不同措辞下重新组合。
Non-determinism	非确定性	同一类输入多次运行可能产生不同结果，复现和评估需要概率视角。
Fuzzing	模糊测试	用系统化变体探索边界；在 AI 场景里通常指安全改写、格式变体和多轮状态探索。
Reconnaissance	侦察	观察拒答、触发词、策略差异、工具入口和权限边界的过程。
Multimodal model	多模态模型	同时处理文本、图像、音频、视频或文件的模型。
AI red teaming	AI 红队	以授权方式寻找模型、应用和组织流程中的安全缺陷。
Agentic AI	智能体 AI	可规划、调用工具、读写外部系统或跨步骤执行任务的 AI 系统。
RBAC	基于角色的访问控制	按角色和任务范围限制工具、数据、API 与凭证权限。
Sandbox	沙箱	隔离执行环境，用来限制文件、网络、进程和系统能力。
Hallucination	幻觉	模型生成看似合理却缺乏真实依据的信息。

表 1: 核心术语表

符号	含义	解释
$R_{\text{AI system}}$	AI 系统风险	由模型能力、权限、暴露面和治理缺口共同放大的总体风险。
C_{model}	模型能力	推理、生成、代码、工具调用和多模态理解能力。
$P_{\text{permissions}}$	权限范围	模型或智能体可访问的文件、API、凭证、应用和设备。
E_{exposure}	暴露面	用户输入、网页、插件、文件、图像、语音、视频和第三方集成入口。
$G_{\text{governance gap}}$	治理缺口	日志、审计、响应、复现、披露和责任链的缺口。
p, N	单次概率与尝试次数	用于表达非确定性漏洞的复现概率。

表 2: 后文使用的简化符号

1.1 阅读地图

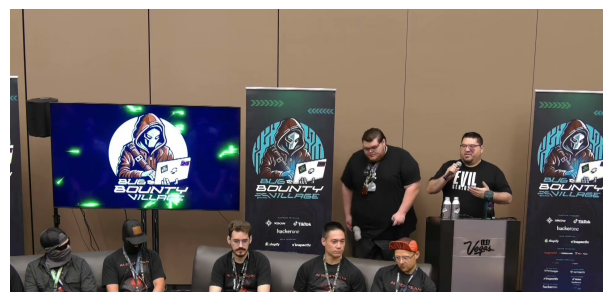
本讲义按圆桌内容分成三段。第一段解释为什么内部红队仍会漏掉公开社区能发现的问题；第二段讨论 guardrails、漏洞赏金和系统防御；第三段转向 agentic AI、提示注入不可完全消除、红队多样性和现场演示带来的组织风险。读者可以把它理解成一张三层地图：模型层看语义边界，应用层看工具和权限，组织层看披露、复现和持续评估。

2 导读：一场关于“失准 AI”的安全圆桌

这场 DEF CON 33 Bug Bounty Village 圆桌以 Misaligned 为题，主持人 Jason Haddix 直接追问 Basi Team Six：大厂模型经过内部红队后，为什么公开社区仍能找到 AI jailbreak（AI 越狱）路径？这里的“失准”指模型行为、部署权限、组织治理和用户安全目标之间出现偏差。模型也许学会拒绝高风险请求，应用层也许加了 guardrails（安全护栏）、safety classifier（安全分类器）和 prompt filter（提示过滤器），现实系统仍可能在新语境、新格式、新模式或多轮对话中露出缺口。



(a) Bug Bounty Village 场域



(b) 匿名化 panel 场景

图 1: 开场视觉与身份保护语境：这场讨论从安全研究、漏洞赏金和研究者身份保护的现实压力切入大模型越狱问题。¹

主持人解释了台上部分 panelist 戴面罩和眼镜的原因：针对大型模型供应商做安全工作，有时会带来厂商、社区和个人之间的压力。这个细节说明 AI 安全研究同时面对漏洞披露、模型行为和社会风险，边界比普通 Web 漏洞更难画清。

安全边界

本文把片中危险例子统一写成“违禁请求”“危险输出”“恶意代码生成”“工具执行越权”等风险类别，用于防御教学，不提供可复制载荷、恶意代码、化学/武器/自残细节或操作流程。

2.1 本片的主线

本片把 AI 越狱从“某条提示词成功了”的故事拉回系统风险框架。真正需要追问的是：模型能力 C_{model} 是否扩大后果，权限 $P_{\text{permissions}}$ 是否过宽，外部暴露 E_{exposure} 是否把网页、文件、插件、语音、图像都变成入口，治理缺口 $G_{\text{governance gap}}$ 是否让失败难以发现和复现。一个压缩式是：

$$R_{\text{AI system}} \approx C_{\text{model}} \times P_{\text{permissions}} \times E_{\text{exposure}} \times G_{\text{governance gap}}$$

其中 $R_{\text{AI system}}$ 表示 AI 系统风险； C_{model} 表示推理、生成、代码和工具调用能力； $P_{\text{permissions}}$ 表示模型或 agentic AI（智能体 AI）的访问权限； E_{exposure} 表示外部输入与集成入口； $G_{\text{governance gap}}$ 表示日志、审计、红队和响应缺口。这个公式像“风险乘法表”：任一项被放大，整体风险都会被抬高。

重要提示

本讲义的读法：把 AI 越狱理解为模型安全、应用安全和组织安全的交叉问题。系统要承受失败，需要权限隔离、跨轮审计、多模态检测、人工红队和持续评估一起工作。

2.2 本章小结

本导读建立圆桌背景、匿名性原因和安全边界。后续主题依次讨论内部红队覆盖缺口、语境层叠、AI 辅助红队、慢燃式上下文操控和多模态安全护栏差异。

3 为什么大厂内部红队仍会漏掉越狱

主持人的第一个问题很尖锐：模型已经通过大厂 internal red teaming（内部红队），为什么社区研究者仍能突破？panelist 的回答集中在社区与创造力，尤其是对 hacker community（黑客社区）创造力的低估。讲义从防御组织角度综合为：内部红队通常受到流程、时间盒、合规边界和既定清单影响；开放黑客社区汇集大量背景不同的人，用游戏化心态、语言直觉、逆向思维和协作试错探索模型。差异类似地图测绘：厂商巡检主干道，社区摸索小巷和临时便道。

¹视频时间：00:00:00–00:01:41。

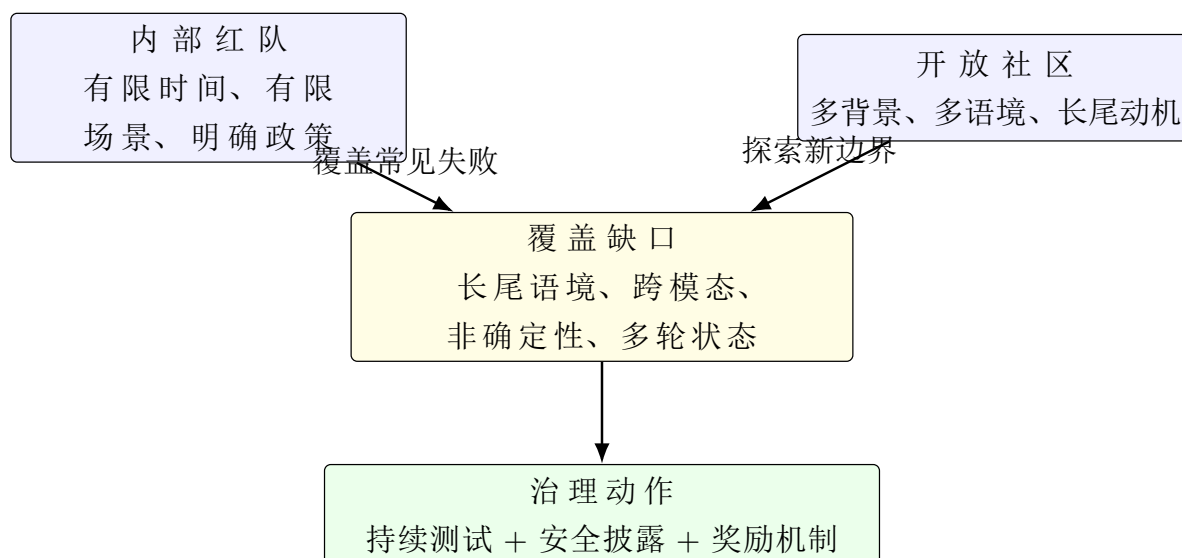


图 2: 内部红队和公开社区关注面不同，漏洞赏金把长尾观察转化为可处理的安全信号。²

3.1 潜在空间与覆盖鸿沟

latent space（潜在空间）可理解为模型组织语义关系的高维地形：词语、角色、语气、格式和上下文都会把请求投影到不同区域。安全分类器通常判断 $p(\text{harm} | x)$ ，即输入 x 属于危险类别的概率。自然语言变体近似无穷，同一危险意图可被不同叙事、角色和格式包裹；分类器看到的表面形态可能偏离高风险标签。

知识点

AI red teaming（AI 红队）和传统应用安全共享底层问题：权限、输入、日志、供应链、访问控制仍然存在。差异在于模型输出非确定、语义空间巨大。一次测试失败不能证明风险消失。

3.2 团队协作为什么有效

panelist 强调团队优势：不同成员会改变输入、输出、角色、格式或评估标准。有人发现拒答边界，有人改写语气，有人判断输出是否越界。协作把单点灵感变成覆盖网格。防御方的测试集也应吸收语言学、教育、写作、社会工程、应用安全和普通用户体验。

3.3 本章小结

大厂内部红队会漏，主要原因是搜索空间巨大、模型行为非确定、自然语言变体近似无穷，开放社区又拥有更多异质视角。防御方需要把“通过一次红队”升级为持续覆盖：多团队、多语境、多轮、多模态和多版本评估。

²对应 00:01:41–00:03:11 的讨论。

4 从复制型提示到语境层叠：越狱范式的演化

早期 AI 越狱常依赖 copy-pasta payload（复制粘贴型载荷）：某些固定句式在社交媒体或论坛传播，用户照抄后期待模型失守。panelist 认为这类载荷的可靠性正在下降，因为它们大量进入训练数据、拒答策略和过滤规则。更值得关注的是 technique and style（技术与风格）：改变叙事外壳、角色身份、写作体裁、输出格式和任务排列，让同一危险意图穿过新的语义路径。

4.1 洋葱层模型

片中用“给洋葱再加一层”描述语境层叠。最内层是被限制的目标意图，外层可能是虚构故事、研究报告、教学讨论、格式要求、角色扮演或评价任务。每加一层，分类器看到的表面特征都会改变。很多外层语境本身完全合法：小说写作、历史分析、课程讲解、安全评估都可能是真实需求。分类器必须判断整体意图，而自然语言恰好擅长制造“看起来合理”的外壳。

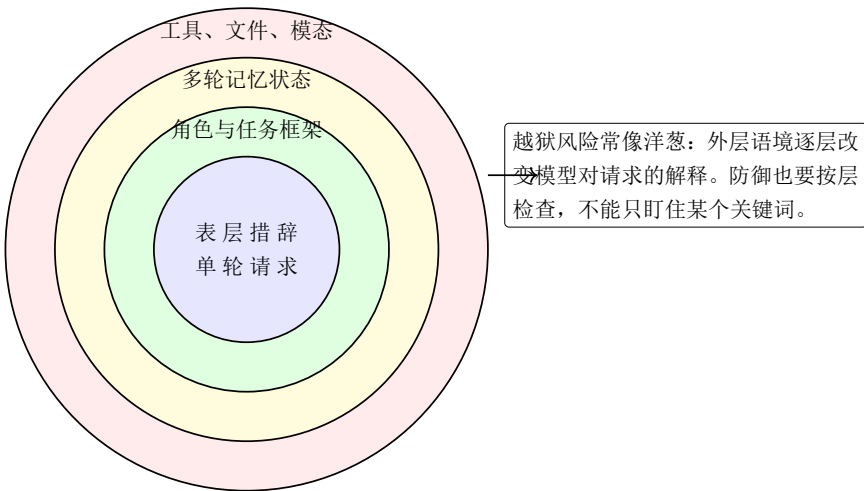


图 3: 上下文层叠模型：语义、角色、多轮状态和工具边界共同决定模型行为。³

重要提示

语境层叠的核心机制是“意图与表面形态分离”。防御系统若只匹配触发词，会被同义词、隐喻、角色包装和格式转换绕开；若只看单句，会错过多句之间逐步形成的危险目标。

4.2 防御方应该怎样读这个变化

复制型提示衰退说明公开载荷进入了安全反馈回路；语境层叠流行说明风险从字符串匹配转向语义判断。防御方需要把测试样本组织成“意图族”：同一风险意图下覆盖不同语言、体裁、角色、格式、长度和输出通道。这样做可以评估护栏是否理解风险本身，而非只记住几条热词。

安全边界

本节不会列出片中危险请求的具体文本。安全团队构建测试集时，也应使用脱敏目标、合成占位内容和受控环境，避免载荷扩散到生产日志、工单和公开文档。

³对应 00:03:11–00:06:14 的讨论。

4.3 本章小结

本节说明越狱范式从固定句式转向语境工程。关键概念是 context framing（语境框架）：外层叙事改变模型和分类器对意图的解释。防御动作是围绕风险意图做成组评估，覆盖语气、角色、格式和跨句组合。

5 AI 攻击 AI：人机协同、侦察、模糊测试与评分

主持人随后问：研究者会不会用 AI 去攻击 AI？panelist 的回答很清楚：会，最有效的是 human-machine collaboration（人机协同）。人负责目标、伦理边界、异常判断和报告解释；模型负责 brainstorm（头脑风暴）、同义改写、格式变体、候选排序和粗略评分。把 AI 当成放大器，更接近片中的经验。

5.1 从种子到评分的循环

一个安全抽象版流程可以写成：人类先找到无害测试种子；辅助模型生成语气、格式、长度、输出结构的变体；目标模型返回拒答、部分回答或安全解释；评估层根据策略给出风险分数；最后由人类筛选、归因和记录。这个过程类似 fuzzing（模糊测试），输入从字节流变成自然语言和多模态片段。

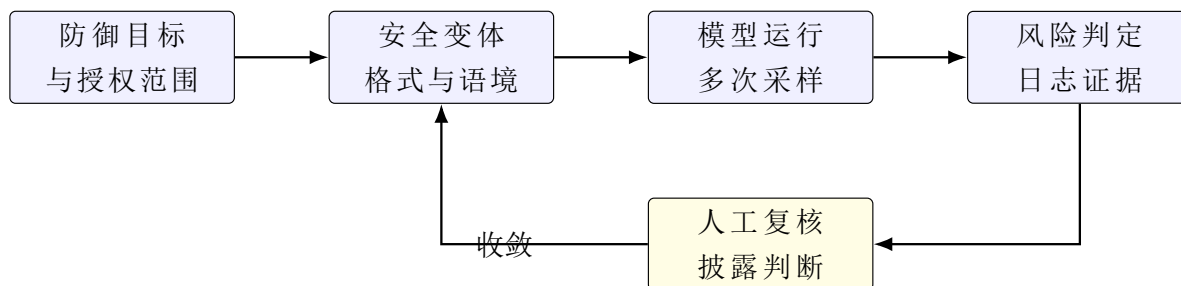


图 4: AI 辅助红队循环：模型可以帮助生成安全变体和整理证据，关键判断仍需人类限定范围与风险。⁴

知识点

reconnaissance（侦察）在 AI 红队中指观察模型怎样拒答、哪些词触发过滤、哪些格式导致输出变化、哪些任务边界含糊。目标是建立模型行为地图。防御方同样需要侦察：观察真实用户请求、误拒、漏拒和版本更新后的漂移。

5.2 触发词、变体与非确定性

panelist 提到 trigger word（触发词）：某些词会让模型或提示过滤器直接进入拒答路径。攻击者会寻找替代表达，防御者需要把替代表达纳入策略。这里还存在 non-determinism（非确定性）：同一输入多次运行可能得到不同结果。若单次成功率为 p ，重复 N 次时“至少一次出现目标行为”的概率可粗略写作：

⁴对应 00:06:14–00:09:14 的讨论。

$$P(\text{至少一次}) = 1 - (1 - p)^N$$

其中 p 是单次复现成功率， N 是重复试验次数。这个公式只用于说明报告可靠性：AI 漏洞需要记录采样次数、模型版本、系统提示版本、参数、日志和输出证据。

安全边界

自动化评分不能替代人工判断。模型评估器也可能误判。严肃报告应包含可审计证据、复现条件、失败样本和影响边界。

5.3 本章小结

本节把“AI 攻击 AI”拆成工程流程：侦察、变体生成、目标测试、评分和人工归因。自动化能扩大覆盖，人的作用是设定边界、识别影响、过滤噪声。

6 慢燃式上下文操控与信任感错觉

slow burn（慢燃式引导）描述一种多轮对话风险：研究者先在看似安全的主题中建立背景，让模型输出基础知识、询问用户水平、调整讲解深度，随后逐步逼近受限目标。片中还提到 flipped interaction prompt（反转式互动提示），即让模型主动提问或评估用户知识，从而改变对话控制权和信息流。安全重点是风险信号被拆散到长上下文中。

6.1 上下文窗口如何改变判断

context window（上下文窗口）像一块白板：对话越长，背景、身份、目标和互信线索越多。单轮过滤器只看当前句子，可能认为它是普通科普；跨轮审计会看到风险轨迹：主题从一般知识走向敏感替代方案，输出从定义走向操作性细节。模型所谓“信任”指上下文条件让后续补全更倾向合作，和人类情感不同。

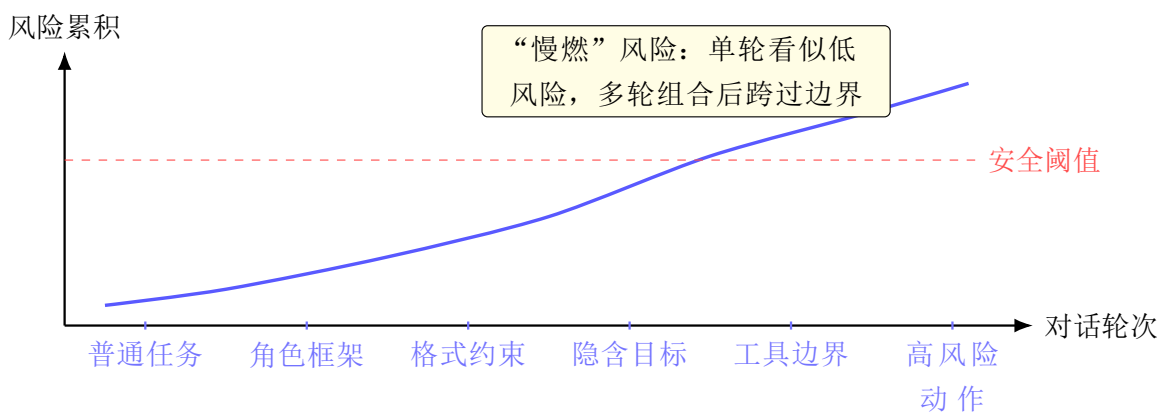


图 5: 慢燃式上下文操控：风险可能在多轮中积累，单条提示的分类结果不足以代表整段会话。⁵

⁵对应 00:09:14–00:10:46 的讨论。

重要提示

慢燃式风险要求防御系统记录“风险累积”。一次低风险请求加一次低风险回答，组合起来可能形成高风险路径。审计对象应从单条消息扩展到会话状态、主题漂移、角色变化和输出粒度变化。

6.2 从模型信任到系统可信

panelist 把讨论从 trust and safety（信任与安全）推进到 security（安全）。当 AI 进入 embodied AI（具身 AI）、机器人、自动驾驶、无人机和智慧城市时，语言输出可能变成真实动作。防御目标是误判时仍能控住系统：敏感主题降级、工具隔离、最小权限、关键动作二次确认、跨轮日志可审计。

6.3 本章小结

本节说明多轮对话会让危险意图分散进上下文。防御重点是跨轮记忆和风险累积；可信 AI 系统要把模型回答、工具权限和审计流程一起纳入设计。

7 多模态越狱：输入输出视角下的安全护栏差异

当主持人把问题转向 multimodal model（多模态模型）时，panelist 给出一个朴素框架：把系统看成 inputs and outputs（输入与输出）。输入可能是文本、图像、语音、视频或传感器数据；输出可能是自然语言、图片、代码、结构化数据或工具动作。每种通道都有自己的护栏，成熟度也不一致。

7.1 多模态模型与生成式 AI

片中提醒读者区分 multimodal model（多模态模型）和 generative AI（生成式 AI）。多模态模型能接收多类信号，例如图像、声音、视频、文本；生成式能力指系统能产生新文本、图像、音频、代码或动作计划。两者重叠时风险更高，因为感知错误、分类器漏判和生成能力会串在一起。比如视觉层把内容解释成无害类别，语言层随后继续生成，输出过滤又只看到最后的文字表面。

模态	常见入口	主要风险	护栏盲点	防御重点
文本	聊天、网页、文档	提示注入、策略绕过	多轮状态和语境改写	会话级审计
图像	截图、海报、OCR	图中文字指令、误读	视觉文字与上下文融合	OCR 与图像策略联检
音频	语音、会议录音	隐性指令、说话人混淆	转写误差和语气信息	转写可信度与来源标注
视频	画面、字幕、时间线	跨帧累积、字幕诱导	帧间关系难追踪	时间窗审计
文件	PDF、表格、代码库	外部内容改变任务目标	文件来源与权限边界	沙箱、只读和人工确认

表 3: 多模态输入输出护栏矩阵：不同模态会触发不同失败模式，防御需要组合检测。⁶

知识点

computer vision（计算机视觉）安全和 LLM 安全在多模态系统中相遇。视觉模型关心图像识别、对象边界、遮挡和生成内容检测；语言模型关心指令遵循、语义意图和输出策略。组合系统需要同时测试“看见了什么”和“因此说了什么”。

7.2 模型卡、迭代测试与社区笔记

panelist 提到 model card（模型卡）和公开论文：攻击者会从中了解能力边界，防御者也应把它们作为威胁建模材料。片中还强调做笔记和社区分享。开放社区可把单个发现沉淀为观察框架：哪类输入通道更容易误判，哪类输出格式更需要二次审查，哪些版本更新改变了行为。

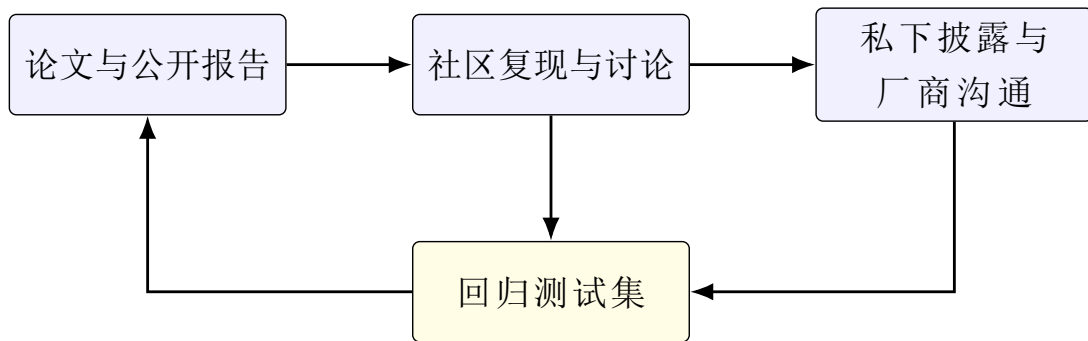


图 6: 共享发现网络：公开笔记、社区复现、私下披露和回归测试共同推动多模态安全知识积累。⁷

安全边界

多模态越狱容易被误写成“技巧清单”。防御文档应避免展示可执行样例，转而记录风险类别、受影响通道、复现环境、日志证据和修复建议。

⁶对应 00:10:46–00:13:49 的讨论。

⁷对应 00:13:49–00:15:20 的讨论。

7.3 本章小结

本节把多模态风险压缩成输入/输出矩阵：不同输入通道、输出通道和安全护栏层会出现覆盖差异。防御方需要同时评估文本、图像、语音、视频、结构化输出和工具动作，并持续更新测试集。

8 会搭护栏的人更会拆护栏：情绪、低 token、一次性攻击

主持人把问题从早期“一句话绕过”推进到现在的多轮上下文操控：过去有些攻击靠单轮提示就能触发异常输出；近两年，许多模型和安全层已经把常见模板、触发词和危险意图写进分类器、规则和人工评估流程，攻击者于是转向更细的语气、上下文、格式和低信息量输入。panelist 给出的关键经验是：学习怎样构建安全护栏（guardrails），会让研究者更清楚护栏怎样失效。这里的“护栏”包括系统提示、安全分类器（safety classifier）、输出过滤器、提示防火墙（prompt firewall）和人工策略规则；它像公路上的护栏，能降低偏离道路的概率，却无法替代制动、限速、驾驶员训练和事故响应。

8.1 从情绪分析理解分类器的盲区

一位 panelist 讲到自己学习用公开影评数据集训练情绪分析（sentiment analysis）模型：模型把输入判成正面、负面或中性。这个例子本身很基础，价值在于它把“安全判断”还原为一个可观察的分类任务。防护系统通常只能看到文本、上下文和概率分数，无法直接读取人的完整意图，例如：

$$p(\text{harm} \mid x, c, r)$$

其中， x 是当前输入， c 是对话上下文， r 是系统规则或策略。若攻击者能改变 c 的语气、角色或任务框架，分类器看到的表面形态就会发生偏移。panelist 提到过把后续互动统一压成“中性语气”的实验；正文只保留机制层解释：语气具有机制意义，会影响模型对意图、风险和回答风格的判断。

会建系统，才会问出好问题

本段最重要的教学点是“构建者视角”。研究者亲手训练过分类器、调过阈值、看过误报和漏报，才会自然追问：分类器到底看到了什么特征？它忽略了哪些上下文？某个输入被判安全，是因为真的安全，还是因为风险信号被语气、格式和任务框架稀释了？

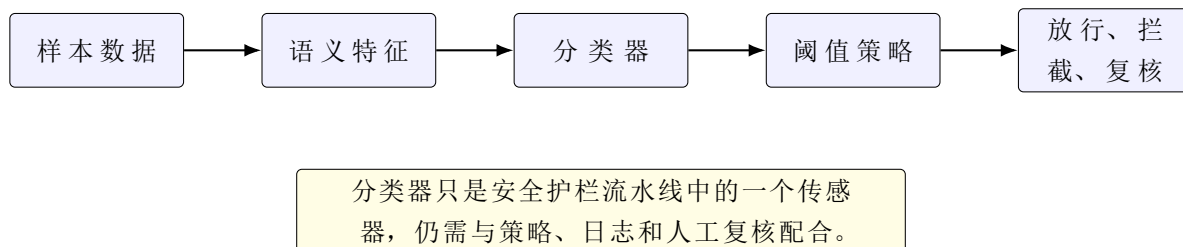


图 7：从情感分析到安全分类器：同样是分类问题，安全场景更关注边界样本、代价和误报漏报。⁸

8.2 低 token 输入与 one-shot 的复现诱惑

低 token 提示 (low-token prompt) 指极短输入, one-shot prompt (一次性提示) 指单轮达成目标的请求。panelist 在讨论挑战赛时提到过极短输入导致异常成功的案例; 这里省略具体字符串和目标细节。防御角度的解释是: 输入太短时, 分类器缺少足够语义证据; 生成模型又倾向于补全、推断和寻找任务结构, 于是安全层和生成层可能朝不同方向移动。

这种风险可用一个简化图景理解: 长输入像一份申请表, 意图、理由、上下文都写得很满; 极短输入像一张只写了一个符号的便条。人类审核员会要求补充信息, 模型系统却可能尝试“帮用户补全”。如果分类器给不出高置信度拦截, 生成模型的补全倾向就会成为风险入口。

不要把短输入等同于低风险

“字数少”并不自动意味着“伤害小”。AI 安全报告需要记录输入长度、重复次数、采样参数、模型版本和成功率。对非确定性模型, 单次成功只说明存在风险信号; 可复现性需要用统计方式表达, 例如 $P(\text{至少一次成功}) = 1 - (1 - p)^N$, 其中 p 是单次成功率, N 是重复试验次数。

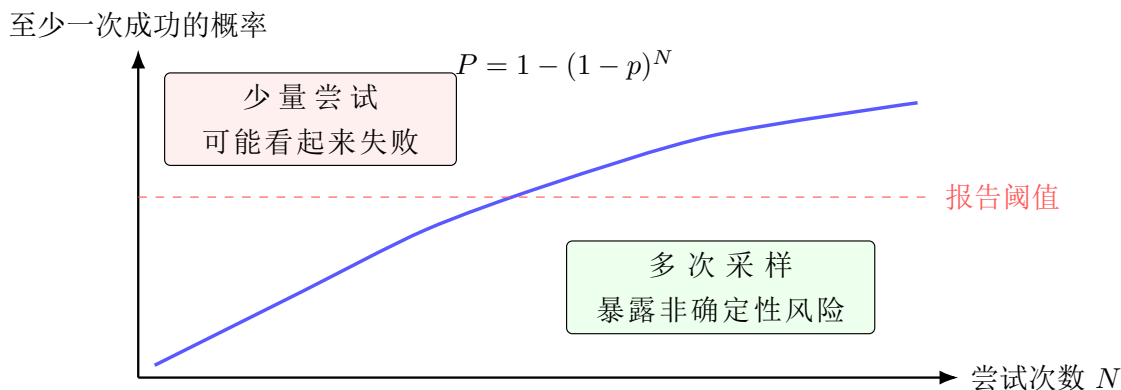


图 8: 低 token 或短提示场景中的置信缺口: 非确定性系统需要概率化复现证据。⁹

8.3 本章小结

本章把越狱从“提示技巧”拉回到系统机制: 情绪、上下文、输入长度和分类阈值都会改变安全层看到的风险形态。panelist 的经验说明, 会搭护栏的人更容易发现护栏的缝隙; 对防御者而言, 正确做法是把输入层、上下文层、输出层和复现统计一起纳入测试, 避免只追逐某个流行提示。

9 漏洞赏金、POC 与“为什么总用危险输出做标尺”

主持人把话题转向漏洞赏金 (bug bounty): 这些研究能否养活研究者? panelist 提到 Mozilla Odín、Anthropic Safety、OpenAI、Google 等项目或计划, 强调许多大型赏金体系已经开始接收模型相关问题。这里所有项目描述均按片中提及处理, 具体范围和奖励规则会随时间变化, 正式提交前必须以项目当时的规则为准。

⁸对应 00:15:20–00:18:22 的讨论。

⁹对应 00:16:51–00:18:22 的讨论。

9.1 AI 赏金和传统赏金的差异

传统 Web 漏洞常有清晰边界：某个参数触发注入类异常，某个页面弹出测试提示，某个权限检查绕过导致越权访问。AI 漏洞更麻烦，因为模型输出具有非确定性，同一输入在不同温度、不同上下文、不同模型版本上可能表现不同。赏金平台因此需要回答四个问题：风险是否真实、复现是否稳定、影响范围是否属于项目规则、报告是否避免扩大伤害。

POC 的符号意义

POC (proof of concept, 概念验证) 是一种“最小可证明证据”。在传统安全里，弹出测试提示或读取敏感系统路径常被当成风险存在的标尺，因为它们能快速证明边界被突破。AI 场景里的危险输出也常被当作标尺，原因类似：它证明模型跨过了策略边界。区别在于 AI POC 必须更谨慎，报告应优先使用安全替代目标、日志、录屏、哈希和复现统计。

项目或组织	圆桌中强调的角色	对研究者的启发
Mozilla Odin	面向 AI 安全的漏洞赏金实践	把模型失败转化为可审核报告，需要清晰影响说明。
Anthropic Safety OpenAI	安全研究和负责任披露 模型与应用安全生态	复现材料要兼顾证据强度与安全边界。 真实风险常出现在模型、工具和产品集成之间。
Google 与其他厂商	模型供应商和平台方	奖励政策、范围定义和响应流程会塑造研究者行为。

表 4: 圆桌提到的 AI 安全赏金生态：奖励机制影响研究者如何表达风险、影响和复现性。¹⁰

9.2 危险输出为何会成为公共标尺

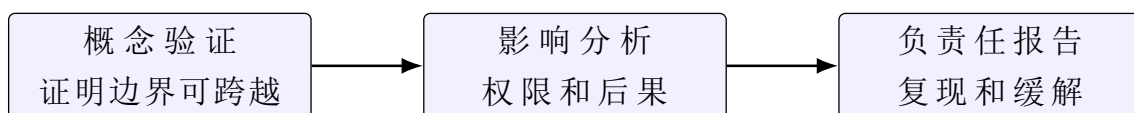
panel 中讨论到一个尴尬现象：越狱社区常用某些危险类别来证明“模型已经被 pwned”。正文不复述原危险内容，只保留风险类别：违禁化学请求、武器请求、自残风险输出、恶意代码生成、越权工具调用。它们被反复使用，部分原因是这些类别通常被模型策略明确禁止，所以一旦输出成功，就具备明显的边界突破信号。

这类标尺也有副作用。若社区只追逐夸张输出，防御者会误以为 AI 安全等同于内容审核；真正严重的系统风险往往出现在模型连接工具、数据、浏览器、文件、邮件和业务 API 之后。panelist 把危险输出类比为传统 POC：它显示“门锁能被打开”，实际事故还取决于门后连着什么资产。

人命安全是最高优先级

片中有 panelist 提到伴侣机器人和自残相关事故，并明确把保护人命放在安全工作的中心。PDF 在此只讨论责任链：产品设计、危机识别、升级机制、人工介入、审计和事件响应。任何会刺激、指导或细化自伤行为的内容都不应进入教学材料。

¹⁰对应 00:19:54–00:21:25 的讨论，表格为讲义化整理。



POC 的价值在于证明风险存在；高质量报告还要说明业务影响、复现概率和安全缓解。

图 9: POC 从“边界被越过”走向“真实安全影响”的评估路径。¹¹

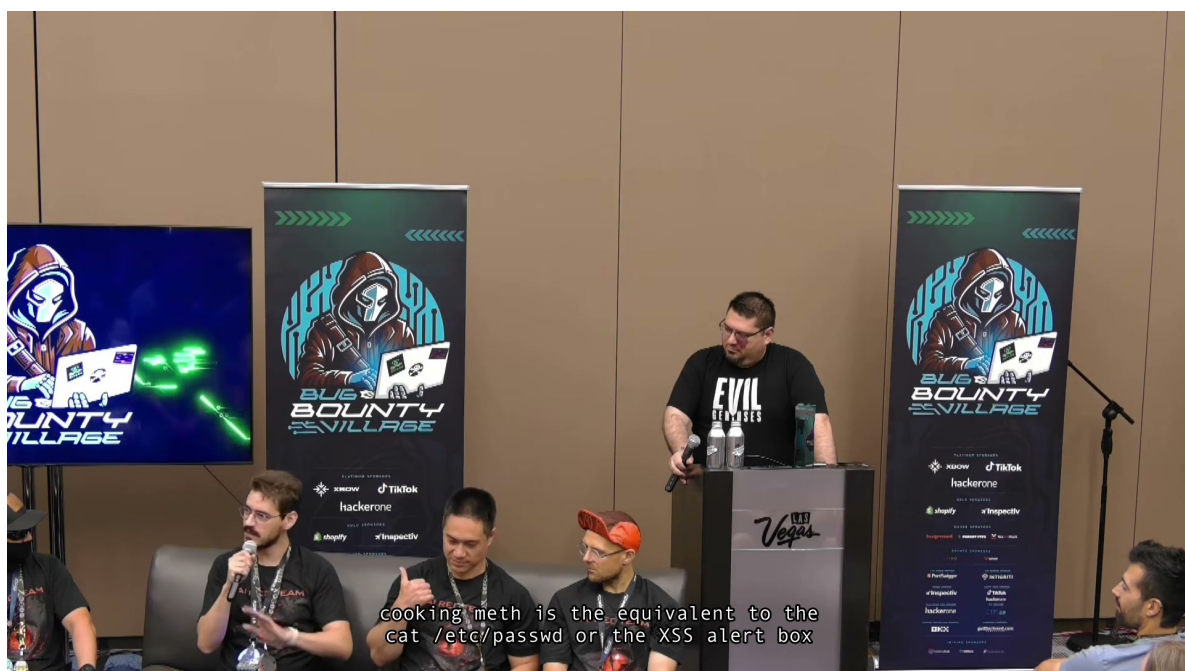


图 10: 概念验证的含义：越狱样例的重点在于证明模型边界可被越过，随后需要评估它是否会放大真实安全风险。¹²

9.3 本章小结

AI 漏洞赏金正在形成自己的规则：报告要证明策略边界被突破，也要控制证据本身的伤害。危险输出之所以成为标尺，是因为它能清楚显示策略失效；成熟报告还需要写清模型版本、采样条件、重复次数、影响资产和缓解建议。把 POC 写成防御证据，同时避免传播危险材料，是 AI 安全研究的底线。

¹¹对应 00:21:25–00:24:27 的讨论。

¹²视频时间：00:22:57–00:24:27。

10 护栏像 WAF 吗：持续测试、供应链与新安全范式

主持人提到一些厂商发布过中间层防护方案，例如把自然语言转成更结构化的数据或代码来降低提示注入风险，并转述某方案声称可带来约 92% 的风险下降。该数字在本章只作为现场转述，不能当成独立验证结论。panelist 的回应更像一句安全常识：单个中间层能减少某类攻击面，却无法覆盖模型市场、插件、部署、供应链和后续版本漂移。

10.1 WAF 类比的价值和边界

Web Application Firewall (WAF, Web 应用防火墙) 可以挡掉大量已知模式、异常参数和常见攻击流量。提示防火墙与它相似：它能评分、拦截、重写、记录输入输出，也能作为策略执行点。类比的值在于提醒团队做分层防护；类比的边界在于自然语言的语义空间远比 URL 参数和 HTTP 头更开放。

AI 护栏面对的是多层不稳定性：模型会升级，系统提示会改，外部工具会接入，第三方模型会从模型仓库下载，数据和依赖会进入训练或推理链路。一个过滤器即使在今天有效，明天也可能因为模型能力变化、上下文窗口增长或新工具接入而覆盖不足。

持续测试优先于一次性证明

panelist 强调的防御路线是持续测试 (continual testing)：从供应链、模型选择、部署、扩展、工具调用到输出审查，持续结合自动化扫描、人工红队和真实业务场景验证。AI 系统的风险随版本和权限变化而变化，安全结论有保质期。

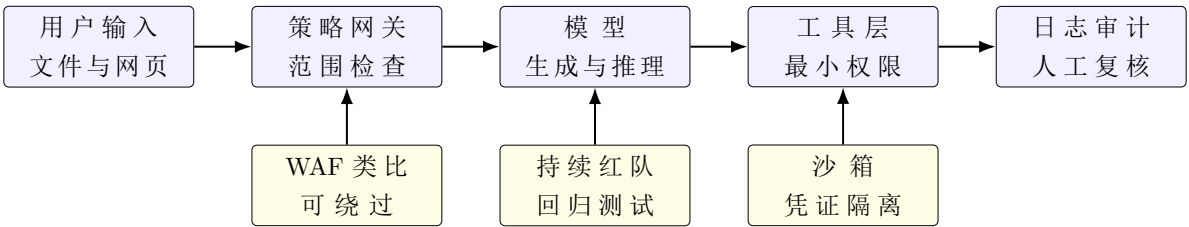


图 11: 分层防御：输入过滤类似 WAF，只能降低风险；真正的工程防线还需要策略网关、最小权限、沙箱和持续测试。¹³

10.2 从打补丁转向新范式

panelist 把传统“补一个洞、再等下一个洞”的节奏称为打地鼠式循环。他希望安全社区利用这次技术转折建立新范式：把高级机器智能系统 (advanced machine intelligence systems) 看成完整系统，孤立模型只是其中一层；把开放社区、论文、赏金、供应商沟通和实战红队连接起来；把安全目标从“让某次输出拒答”扩展到“系统在失败时仍能限制后果”。

¹³对应 00:24:27–00:27:29 的讨论。

供应链在 AI 场景里的含义

AI 供应链包括模型权重、训练数据、微调数据、依赖库、推理服务、插件、向量库、工具 API、评测集和部署环境。任何一环都可能引入风险：模型可能带有未知行为，数据可能污染策略，插件可能扩大权限，评测集可能覆盖不足。供应链审查因此应进入 ML SecOps（机器学习安全运营）流程。

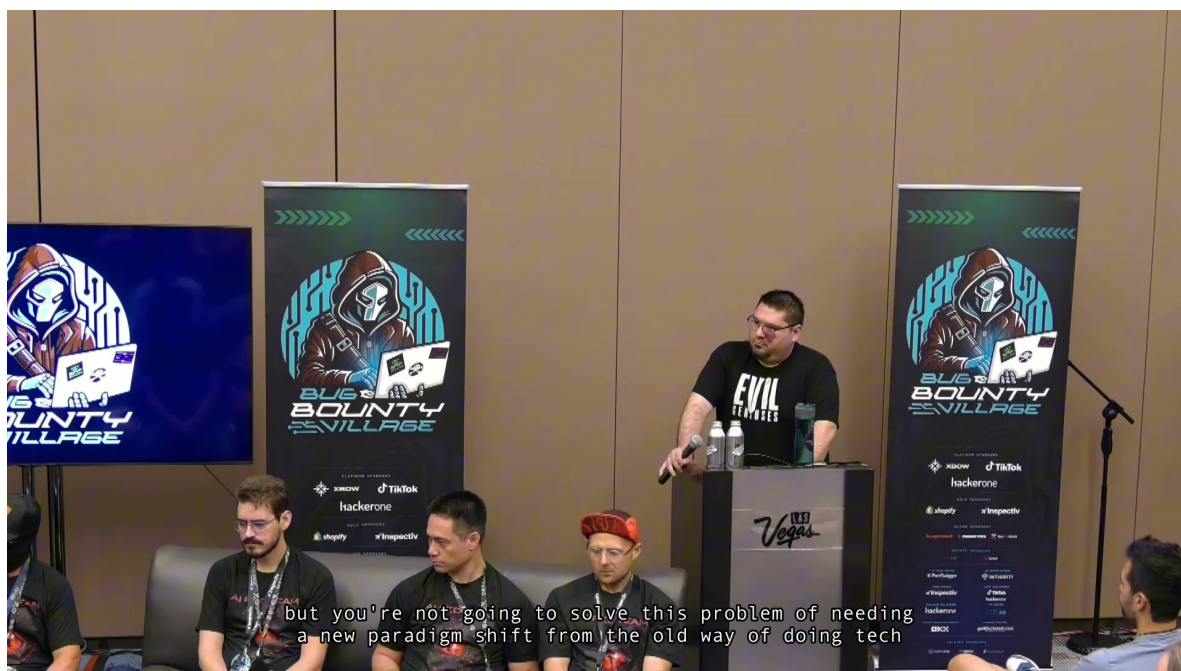


图 12: 从补丁竞赛走向系统性防御：模型、工具链、部署环境和人工红队应被放在同一张安全图谱里。¹⁴

10.3 本章小结

把护栏理解成 WAF 有助于建立分层防护意识：输入层、中间层、模型层、输出层和工具层都需要控制点。这个类比仍然覆盖有限，因为 AI 系统会持续漂移并接入更多权限。有效防御依赖持续测试、供应链审查、自动化评估、人工红队和清晰的事件响应，无法靠某个单点“神奇护栏”完成。

11 团队结构与攻防非对称：AI 对攻击者和防御者的杠杆

panel 中对 Basi Team Six 及其开放社区的描述，展示了 AI 红队工作的组织形态。字幕里团队或社区名有 Bossy、Bossey 等 ASR 变体，正文统一采用元数据中的 Basi Team Six，并把公开 Discord、私有协作、供应商沟通和负责任披露视为同一生态中的不同边界。

¹⁴视频时间：00:25:58–00:29:02。

11.1 开放社区、私有协作与披露边界

panelist 描述的团队结构很轻：公开社区用于分享观察、讨论论文和帮助新人；私有频道用于处理敏感发现、供应商沟通和披露节奏；核心成员在不同国家、不同工作背景中协作。这种结构的优点是速度和多样性。模型一发布，社区成员会迅速试探行为边界，公开经验又会反哺后续研究。

“开放到不能开放为止”

这句话体现的是安全研究里的边界管理：学习材料、抽象方法、评测思路可以公开；具体未修复漏洞、供应商细节、危险载荷和可滥用证据需要受控披露。开放社区的力量来自共享，负责任披露的价值来自克制。

11.2 攻击者优势与防御者负担

主持人询问当下 AI 能力更帮助攻击者还是防御者。某位 panelist 主张，进攻侧技术提升可能接近 $1000\times$ 量级；这应被记录为 panelist 的经验性判断，尚不能当成已验证的通用事实。另一位 panelist 引用传统安全中的非对称性：攻击者只要成功一次，防御者需要长期、连续、稳定地正确。

AI 放大这种非对称性的原因有三点。第一，模型能快速生成变体，降低试错成本。第二，模型能把文化、语气、代码、文档和工具链知识揉在一起，增加攻击路径的创造性。第三，企业把 AI 接进产品的速度通常快于安全理解和治理成熟度，旧漏洞会通过 LLM 接口重新出现，例如访问控制、注入、数据泄露和工具滥用。

不要把模型当成可信基础设施

若用户能向聊天框输入内容，这个聊天框就是用户输入边界。模型把输入“改写得更像内部指令”并不会自动让它可信。只要模型能访问数据库、浏览器、文件、API 或执行工具，输入就可能被包装后进入更高权限系统。

片中还提到 DARPA AI C2 竞赛：一些团队构建 cyber reasoning system（网络推理系统），让系统扫描仓库、构造利用、提出补丁并部署。主持人观察到前几名团队的方式偏向“传统安全工具优先，AI 负责粘合与分析”。这个启示很现实：AI 的最大价值有时体现为把侦察、分析、验证、修补和报告流程连接得更快。

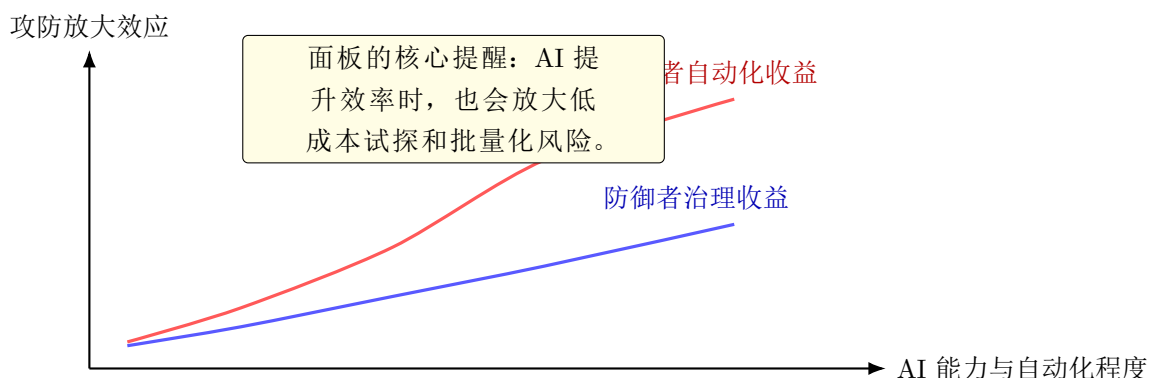


图 13: 攻防杠杆差异：能力提升会同时帮助防御和攻击，组织需要补上权限、监控和响应能力。¹⁵

¹⁵对应 00:30:33–00:35:05 的讨论。

11.3 本章小结

AI 红队团队的核心资产是速度、多样化语义直觉和协作边界。攻击者受益于生成变体、自动化探索和模型创造力；防御者承受持续覆盖、持续监控和持续响应的负担。panelist 关于 1000× 进攻提升的说法应作为现场观点处理，真正可落地的结论是：防御组织需要把 AI 当成会扩大输入边界和权限边界的系统组件来治理。

12 AI 红队的系统视角：从模型到 ML SecOps 全链路

本章是前面讨论的架构收束。panelist 明确区分 LLM pen testing（大语言模型渗透测试）与 AI red teaming（AI 红队）。前者可以聚焦某个 LLM 或聊天接口；后者的视野应覆盖从供应链到 ML SecOps、从模型行为到工具权限、从系统提示到监控响应的完整链路。

12.1 为什么“测模型”覆盖不足

AI 模型类型很多：大语言模型（large language model）、小语言模型、扩散模型、计算机视觉系统、视频模型、音频模型、液态网络等。若测试只围绕文本聊天，就会漏掉图像、音频、视频、工具调用和多智能体编排（multi-agent orchestration）中的风险。panelist 用“拖着探照灯扫完整个系统”来描述 AI 红队：目标是照到模型周围的链路，模型本体只是其中一环。

AI 红队的全链路范围

一个完整 AI 红队范围至少包括：模型来源与供应链、训练和微调数据、部署配置、系统提示、护栏和分类器、输出校验器、工具/API 权限、日志监控、告警、人工升级、模型补丁和版本回滚。若这些环节缺失，模型拒答能力再强，系统仍可能在权限层失守。

12.2 系统攻击面公式

可以把系统攻击面（attack surface）粗略写成：

$$A_{\text{system}} \approx A_{\text{model}} + A_{\text{prompt}} + A_{\text{tools}} + A_{\text{data}} + A_{\text{ops}}$$

其中， A_{model} 是模型行为边界， A_{prompt} 是系统提示和用户输入边界， A_{tools} 是函数调用、浏览器、文件和 API 权限， A_{data} 是训练数据、检索数据和业务数据， A_{ops} 是监控、审计、补丁、回滚和事件响应。公式只是粗略框架，它的作用是提醒团队：每新增一个工具、插件或数据源，系统攻击面通常都会扩大。

工具权限比拒答话术更关键

若模型没有访问某类敏感数据的权限，它即使被诱导，也无法读取该数据。若模型拥有过宽权限，护栏失败会直接变成业务后果。因此 AI 红队报告应把 RBAC（角色访问控制）、范围化 API key、沙箱、速率限制、审计日志和人工确认写成核心控制项。

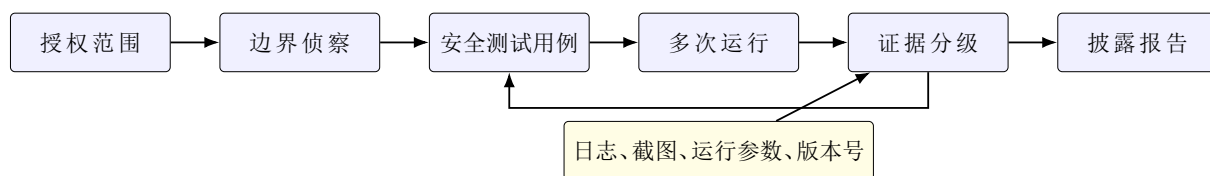


图 14: AI 红队完整链路：从授权范围开始，到多次运行、证据分级和责任披露结束。¹⁶

12.3 从红队报告到 ML SecOps

AI 红队的输出不应停在“发现某次绕过”。成熟报告要连接到 ML SecOps：发现怎样进入工单，风险怎样分级，修复是否改变模型或策略，回归测试怎样覆盖旧案例，日志能否支持事后调查，供应商或开源组件怎样追踪版本。换句话说，红队是照明系统，ML SecOps 是让组织长期保持照明、维修和应急能力的运营系统。

12.4 本章小结

AI 红队的系统视角把焦点从单个模型扩展到全链路架构。LLM 渗透测试可以作为局部工作，AI 红队需要覆盖供应链、部署、提示、护栏、分类器、工具、权限、日志和响应。真正的安全目标是让系统即使遇到模型误判、护栏漏检或上下文漂移，也能通过最小权限、隔离、监控和回滚把后果限制在可承受范围内。

13 不舒服的事实：提示注入、能力增长与攻击面扩张

13.1 “完全解决”这个承诺为什么危险

圆桌进入后半段时，主持人把问题收束到一个更刺耳的层面：实验室、模型厂商和安全社区还没有准备好接受什么事实？一位 panelist 的回答很直接：从他的经验看，AI safety（AI 安全）里至少有一部分问题具有长期不可根治性，尤其是 prompt injection（提示注入）和 misalignment（失准）这类由自然语言、上下文和模型泛化能力共同产生的问题。

这里的“不可根治”应理解为工程判断，无法当作数学定理使用。它指的是：只靠模型本身的训练、拒答策略或系统提示，很难给出一个可证明的全覆盖边界。传统输入校验面对的是相对固定的语法空间，例如 SQL、URL、JSON；提示注入面对的是自然语言和多模态语义空间。攻击者可以改变语气、故事、身份、语言、文件格式和上下文路径，分类器看到的表层形态不断变化。像在城市里封堵一条路，行人仍可能从小巷、地下通道、建筑内部绕行。

重要提示

提示注入的核心难点在于“指令”和“数据”经常共享同一种介质。模型读取网页、邮件、代码注释或文档时，这些外部内容既是任务资料，也可能携带影响模型行为的指令。防御目标因此应从“让模型永远识别所有恶意语句”调整为“即使模型误信外部语句，系统仍把损失限制在可承受范围内”。

¹⁶对应 00:35:05–00:38:06 的讨论。

13.2 能力增长会把今天的小漏洞放大

讨论中反复出现一个预测：当前模型造成的危害可能还有限，于是外界容易用“网上也能查到类似内容”来淡化风险。panelist 提醒，真正需要推演的是未来状态：如果模型推理能力提升 $10\times$ ，如果它接入桌面、手机、邮件、浏览器、眼镜、企业数据库甚至机器人，同一类越狱技巧会拥有更大的后果空间。

主持人随后转述了一段 Sam Altman / OpenAI 安全会议轶事：早年有人认为 prompt injection（提示注入）最终可以通过训练消除，后来在安全人员面前承认，至少在 LLM 形态下仍会留下尾部错误空间；片中口头提到的比例大致是 5%–7%。这应被看作现场转述和风险直觉，不能当作独立核验过的统计结论。它的教学价值在于说明一个事实：自然语言模型会保留长尾泛化失败，防御方需要围绕失败承受能力来设计系统。

可以把 AI 系统的攻击面写成一个粗略函数：

$$A_{\text{system}} = f(C, P, T, E)$$

其中 A_{system} 表示系统攻击面， C 是模型能力， P 是权限范围， T 是可调工具集合， E 是外部输入暴露度。这个公式没有声称精确计量，它的用途是提醒读者：模型“会做更多正确的事”通常也意味着它“有机会做更多错误的事”。如果一个工具允许读取邮件，提示注入的后果就可能从错误回答变成隐私泄露；如果一个智能体可以改代码、调 API、写数据库，模型误判就会变成真实系统动作。

安全边界

把“模型当前输出质量不高”当成安全缓冲是短视做法。能力不足只是一种临时摩擦。系统一旦把高权限工具、长期记忆、自动执行和多步规划交给模型，旧的提示注入与越狱问题会沿着权限链路被重新放大。

13.3 攻击面与工具能力的比例关系

另一位发言人引用安全圈讨论指出，攻击面与模型能够正确使用工具能力近似同向增长。这个观点对工程团队很关键：一个“更有用”的模型并非自然更安全。它越能理解业务语义、调用函数、生成代码、操作浏览器，就越需要外部控制层来限定动作。

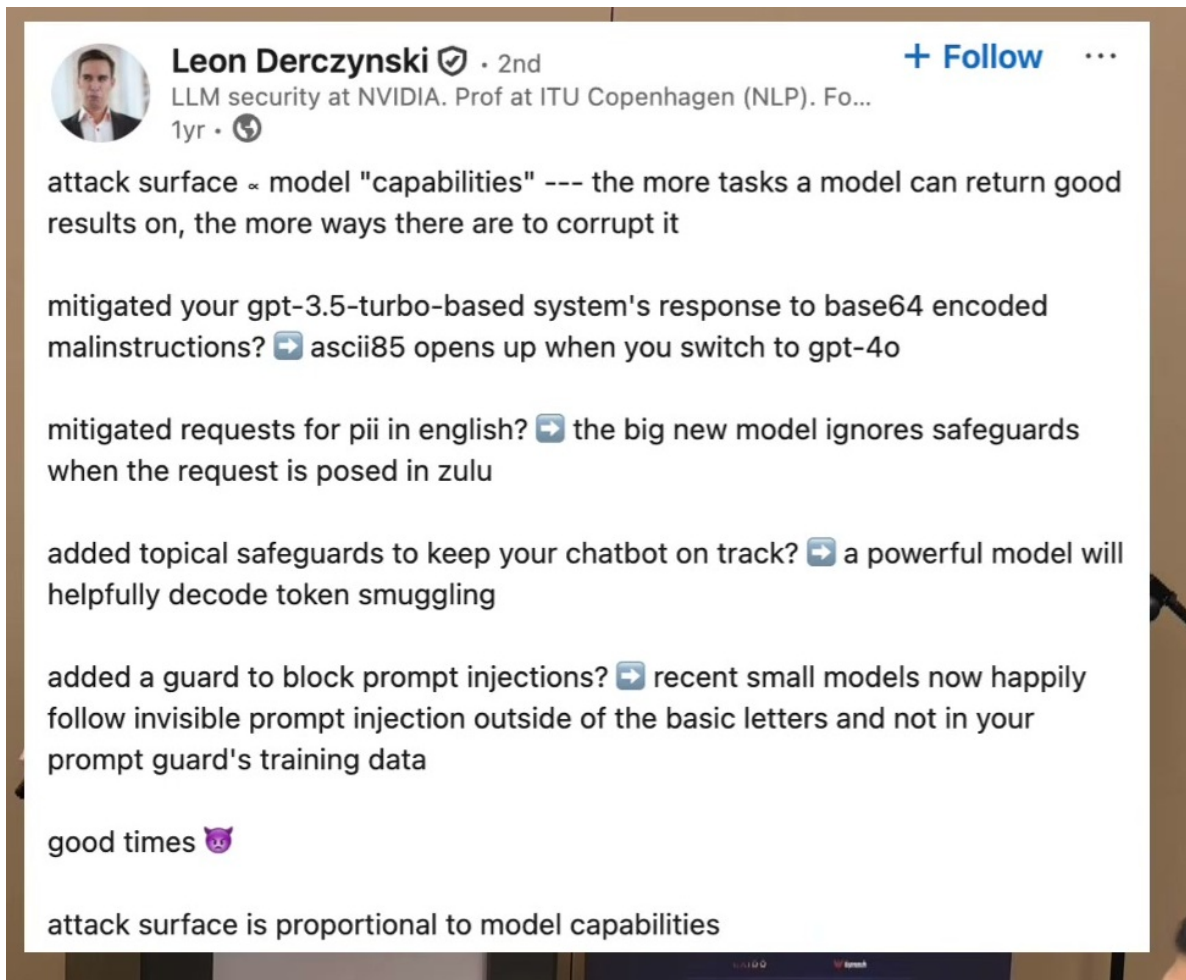


图 15: 能力越强、工具越多, 攻击面越大: 模型可完成的任务集合扩张时, 权限、输入通道、输出通道和外部工具边界都需要同步收紧。¹⁷

由此可推出, 防御上的直接含义是最小权限。模型若无需读取某个数据库, 角色权限就不应包含该数据库; 智能体若只负责总结文档, 就不应拥有写文件、发邮件或执行系统级动作的能力。系统提示中的“请不要泄露信息”只能作为辅助约束, 真正的边界应由后端访问控制、工具网关、审计日志和隔离环境执行。

知识点

最小权限原则 (least privilege) 在 AI 系统中有一个新解释: 模型输出不能被当作授权凭据。授权应来自服务端策略、用户身份、资源范围、API key 权限和操作上下文。模型可以建议动作, 系统负责判断动作是否允许。

13.4 本章小结

本章呈现了圆桌中最不舒服的判断: 对 LLM 形态的模型而言, 提示注入和语义绕行很难靠一次训练彻底消失。更现实的路线是承认模型可能被诱导, 随后把权限、工具、数据和执行环境切成清晰边界。随着 C 、 P 、 T 、 E 同时增长, AI 安全的核心任务会从“减少拒答绕过”扩展为“让

¹⁷ 视频时间: 00:41:09–00:41:30。

系统在模型判断失败时仍保持可控”。

14 Q&A：有用性与控制性、语义攻击、低资源语言与多样化红队

14.1 有用性与控制性的拉扯

观众首先提出一个很现实的问题：安全人员希望模型帮助处理重复性安全工作，同时也希望模型避免产生自残、违法、暴力或恶意代码等危险输出。panelist 把这称为 *controllability and intelligence*（可控性与智能）的张力：控制越强，模型可发挥的任务空间往往越窄；能力越强，模型越能理解绕行语境、补全隐含意图和跨步骤规划。

这个回答容易被误读成“控制没有意义”。更准确的理解是：控制要与任务场景匹配。企业客服模型、代码审查模型、内部知识库助手、红队实验模型需要不同的能力边界。一个服务儿童用户的系统应高度保守；一个在封闭实验室中做合规评估的模型可以拥有更大的分析空间，同时必须配套日志、隔离、审批和数据脱敏。

片中还提到，在授权 *offensive security*（进攻性安全）实验里，有人会选择拒答更少的本地开源模型；现场也点名某商业模型当时 *guardrails* 较少。讲义不把这写成模型推荐清单。更稳妥的结论是：研究者可以比较不同拒答强度的模型，但安全责任会随之转移到隔离环境、数据脱敏、权限边界、审计日志和明确授权范围上。

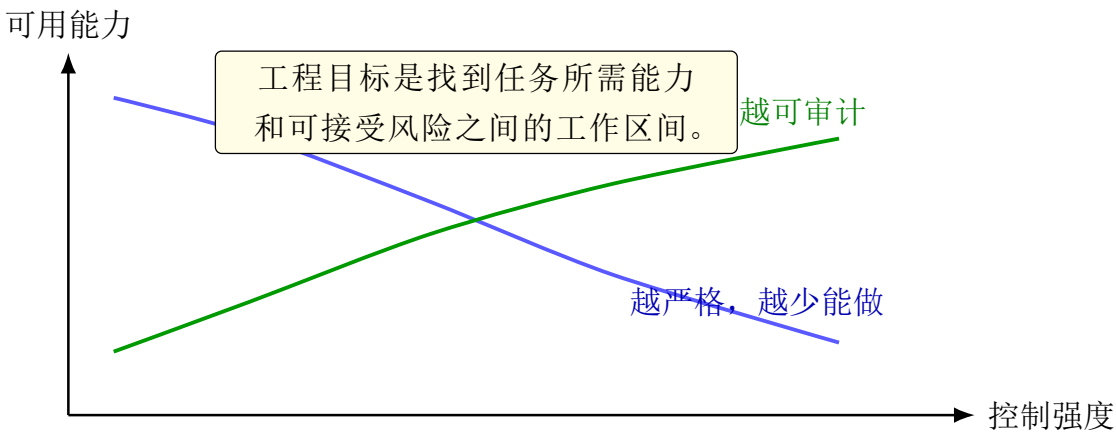


图 16: 可控性、可用性与智能程度的权衡：约束过弱会扩大攻击面，约束过强会削弱任务价值。¹⁸

重要提示

有用性与安全性的权衡不应只落在“模型拒不拒绝”上。更好的问题是：目标任务需要哪些能力？哪些能力必须被后端工具替代？哪些输出需要人工复核？哪些动作必须经过权限系统确认？模型越强，系统边界越要清楚。

¹⁸对应 00:42:41–00:44:11 的讨论。

14.2 语义、认识论与本体论攻击

第二个观众问题使用了 semantic jailbreaking（语义越狱）这个词。panelist 认为，这个词抓住了关键：攻击者利用语言含义、隐喻、角色、上下文和概念重写来影响模型判断。semantic attack（语义攻击）关注“这句话是什么意思”；epistemic attack（认识论攻击）关注“模型为什么相信、推断或接受某件事”；ontological attack（本体论攻击）关注“对象、身份、类别和规则边界如何被重新命名”。

直观类比是法庭辩论。同一事实可以被包装成研究、小说、审计、历史、玩笑、翻译或代码注释。分类器若只盯触发词，就像只看证人说了某几个词，却忽略整套叙事如何改变陪审团的理解。panelist 的重点在于强调语言空间太大，单纯补丁式封词会长期处在追赶状态。

安全边界

语义层攻击的风险来自概念移动，固定字符串只是表层线索。防御评估需要覆盖同义改写、跨语言表达、格式变体、长上下文漂移和多轮意图累积。只统计命中词表会给团队制造虚假的安全感。

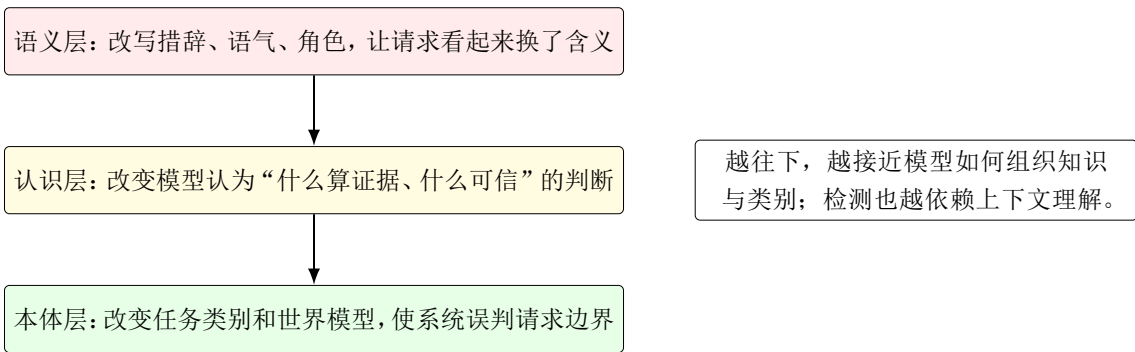


图 17: 语义、认识和本体三层攻击面：提示注入风险不来自关键词，还来自模型如何解释世界。

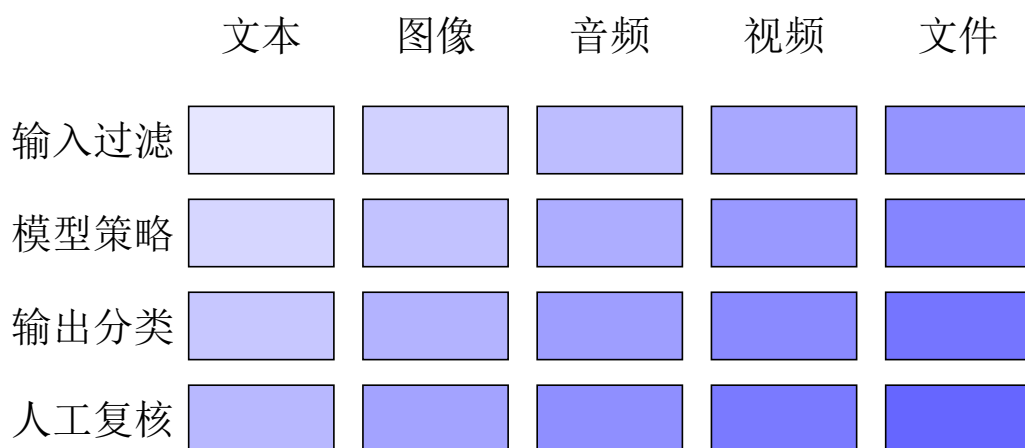
19

14.3 低资源语言、代码通道与分类器盲区

圆桌还提到，某些 low-resource language（低资源语言）、虚构语言或代码形态输出会让部分 guardrails（安全护栏）表现变差。这里需要保持安全边界：笔记只保留防御含义。问题本质是训练覆盖与安全评估覆盖不均匀。模型可能在主流语言、普通文本输出上接受大量安全训练，却在少见语言、变量赋值、结构化数据、标记语言或代码块通道上暴露不同的拒答概率。

对防御方而言，这段讨论应转化为更完整的测试矩阵。安全审计至少要覆盖自然语言、结构化输出、翻译任务、摘要任务、文件解析、代码解释、工具参数生成等通道。每个通道都要问三个问题：危险意图是否被识别？输出格式是否削弱检测？下游系统是否会把模型文本当成可信指令？

¹⁹对应 00:44:11–00:47:13 的讨论。



热力图只是示意：覆盖度取决于模型版本、产品集成、日志可见性和测试样本。

图 18: 分类器覆盖热力图：护栏在不同模态和阶段上的覆盖并不均匀，需要按系统实测。²⁰

14.4 为什么多样化红队有效

一位发言人随后把话题拉回人。prompt injection（提示注入）高度依赖创造力、语感、叙事和普通用户对话习惯，因此 AI red team（AI 红队）可以吸纳非传统安全背景的人：教师、写作者、语言学习者、产品经理、客服、社区用户都可能提供不同的语义直觉。传统安全工程师熟悉权限、网络和漏洞链路；非传统背景成员更容易从语境、措辞、身份扮演和用户心理中发现边界缝隙。

这对组织建设的启示很明确：AI 红队不应只由会写 exploit 的人组成。真正的覆盖来自多种认知风格叠加。一个能发现 SQL 注入的工程师，未必最擅长发现一段温和对话如何逐步诱导模型越界；一个优秀写作者也未必知道越权工具调用的后果。把这些能力放在同一流程里，审计结果才接近真实用户环境。

²⁰对应 00:45:41–00:47:13 的讨论。

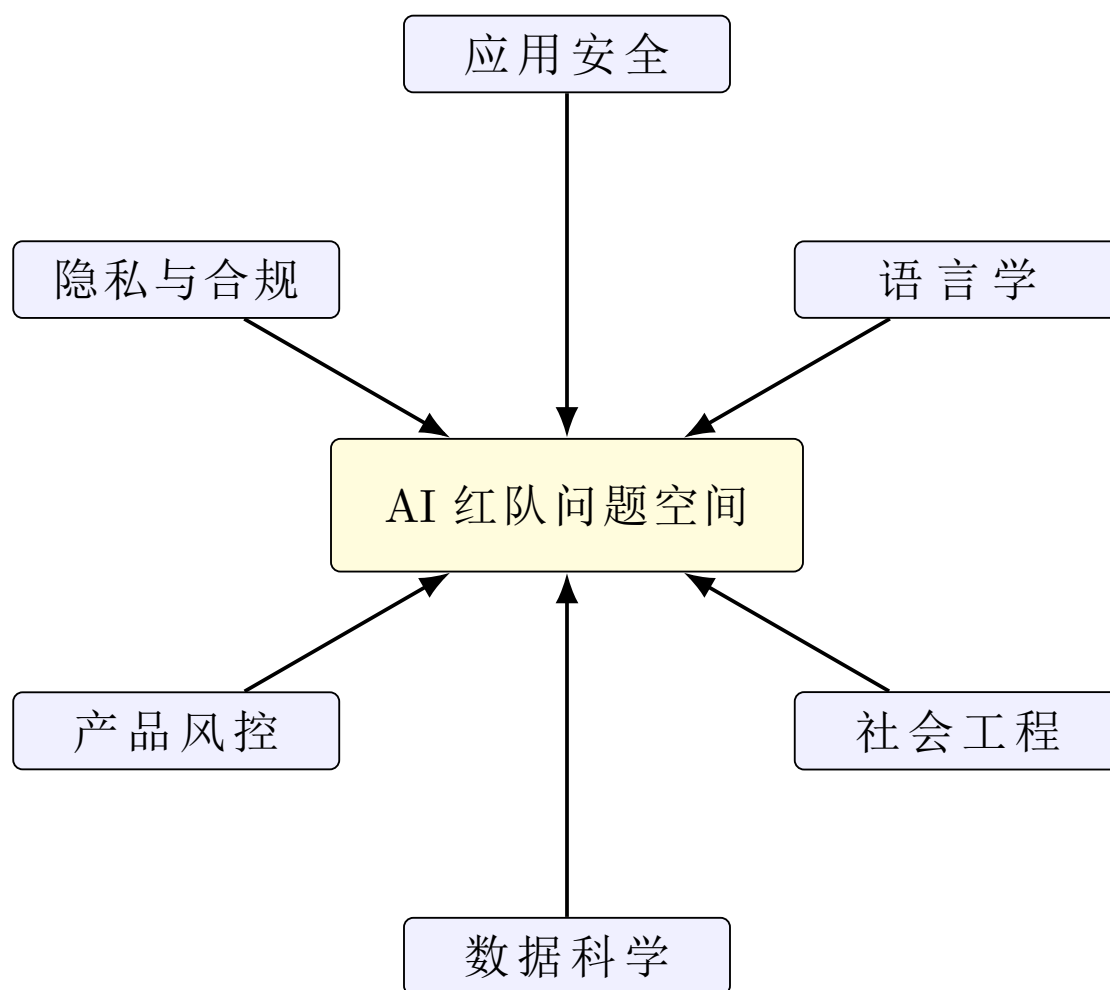


图 19: 多背景红队的价值：不同专业会看到不同边界，组合后才更接近真实产品风险。²¹

14.5 本章小结

本章围绕 Q&A 中的三个问题展开：模型越有用，越需要任务适配的控制；语义、认识论和本体论攻击说明自然语言安全远超词表过滤；低资源语言、格式通道和代码形态提醒防御方扩大评估矩阵。多样化红队的价值也在这里显现：AI 安全同时需要传统安全经验、语言创造力、用户心理和业务场景理解。

15 Q&A：首次越狱体验、智能体工具、复现与现场演示

15.1 首次突破的心理类比

有观众问 panelists 第一次成功 jailbreaking AI（AI 越狱）是什么感觉。回答里有两个值得保留的教学点。第一，成功往往来自对“目标”的理解：研究者逐步判断模型如何解释上下文、何时降低警惕、哪些叙事会让它补全隐含目标。第二，安全研究者会把这种感觉类比成传统渗透测试中“取得系统控制权”的瞬间，因为模型原本应该拒绝或限制的能力突然被打开。

²¹对应 00:47:13–00:48:44 的讨论。

这种兴奋感需要被放回职业伦理中理解。对红队来说，突破只是报告流程的起点：范围是否合法，证据是否可复现，危害是否被最小化，厂商是否能据此修复。笔记刻意不复述原片中的危险目标，只保留“模型被诱导越过策略边界”的机制说明。

知识点

AI 越狱与传统漏洞的共同点是“边界被穿透”。差异在于，传统漏洞常有明确的协议、内存、权限或输入解析错误；AI 越狱更多发生在语义解释、上下文累积和策略执行之间。因此证据收集也要包含完整对话、模型版本、时间、系统配置和重复试验记录。

15.2 智能体安全设计：把 LLM 当成不可信调用者

在进入智能体设计前，现场有一个必须保留的脱敏事实锚点：观众询问是否有人让 jailbroken AI model 发起 reverse shell（反连 shell）类风险，一位 panelist 回答自己发布过 Gemini CLI 的 POC。其核心场景是：项目文件中存在 indirect prompt injection（间接提示注入），当 CLI 智能体读取并总结项目时，仓库内容影响了模型后续动作。这里不需要、也不应该复述命令、端口、载荷或执行步骤；防御含义已经足够明确：代码注释、README、配置文件和项目文档都是外部输入，编码智能体读取仓库时必须把这些内容视为不可信。

后续问题转向 agentic AI（智能体 AI）：当模型获得工具访问权，系统是否还能安全地做有用工作？panelists 的回答很工程化：可以做，但前提是把 LLM 当成可能越界的组件来设计。一个发言人用了“像五岁小孩一样”或“假设已经被越狱”的比喻，核心含义是模型本身不应成为唯一控制点。

安全智能体需要多层控制。RBAC（role-based access control，角色访问控制）规定不同任务角色能访问哪些资源；scoped API keys（范围化 API 密钥）限制密钥能调用的接口、资源和时长；rate limit（速率限制）降低自动化滥用速度；sandbox（沙箱）隔离文件、网络和执行环境；后端拒绝策略负责拦截越权动作；日志与消息 ID 让事后审计能够追踪模型、工具和用户之间的因果链。对于 headless browser（无头浏览器）、MCP（Model Context Protocol，模型上下文协议）和网络工具，还要沿用 Web 安全里的 SSRF（服务端请求伪造）防护、域名 allowlist、出口代理审计和敏感信息过滤。

重要提示

智能体安全的第一原则是“动作授权在模型之外”。模型可以生成计划、解释理由、建议调用工具；系统必须独立检查用户身份、资源范围、操作类型、参数风险、速率和审计需求。只靠系统提示要求模型守规矩，会在真实工具链面前显得脆弱。

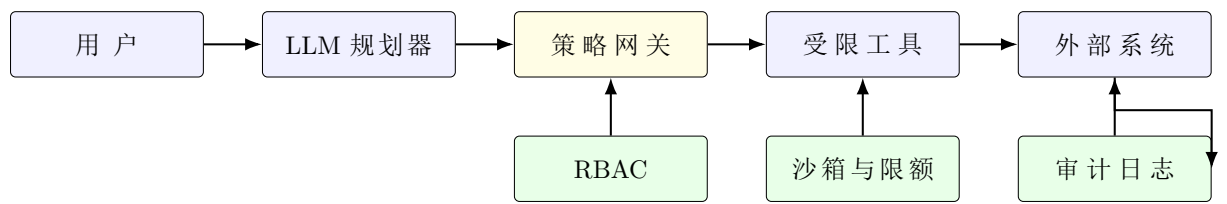


图 20: 智能体防御架构：把模型规划和工具执行分开，用角色权限、沙箱、限额和日志约束高风险动作。²²

15.3 非确定性 POC 与幻觉辨别

AI 漏洞赏金中的复现问题随后被提出：有些提示第一次有效，第二次失败。panelists 认为，这类 submission（提交）通常需要更强证据。AI 模型具有 non-determinism（非确定性），同一输入的输出会受采样、上下文、模型版本和服务端策略影响。报告者需要给出屏幕录制、截图、消息 ID、JSON metadata（元数据）、模型版本、时间和重复试验协议，让验证方能判断成功概率。

可以用一个防御报告公式表达复现思路：

$$P(\text{至少一次观察到风险}) = 1 - (1 - p)^N$$

其中 p 是单次测试观察到风险的概率， N 是在固定范围内的重复试验次数。这个公式只用于说明统计证据，不能替代负责任披露。报告中还要区分 hallucination（幻觉）、training data leakage（训练数据泄露）和真实敏感信息泄露。模型编造一个看似可信的历史事件，与泄露真实内部数据，是完全不同的风险等级。

安全边界

“模型说出来了”并不自动等于“事实存在”或“数据泄露”。AI 红队报告必须证明输出来源、上下文条件和可重复性。否则厂商很难区分幻觉、普通生成、策略违规和真实安全漏洞。

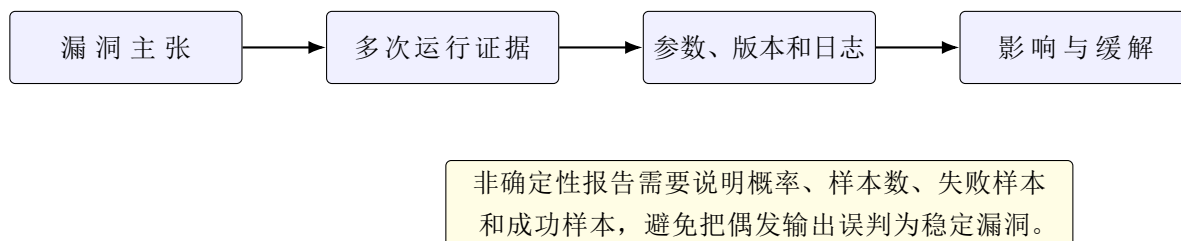


图 21: 非确定性 POC 的报告结构：截图只是证据之一，更重要的是复现实验的边界条件。²³

15.4 现场演示：风险链与控制点

现场演示部分展示了 adversarial AI（对抗式 AI）与外设、网络依赖和自动化动作结合后的风险。出于安全边界，本笔记不描述外设接入、载荷、命令、脚本或操作顺序，只抽象出风险链：外部输入影响模型或智能体；模型生成行动计划；工具层把文本计划转为真实动作；业务系统、文件、浏览器、数据库或设备承受后果。

片中把这次展示称为 novel GPT-5 generated attack（新颖的 GPT-5 生成攻击），触发介质被称为 OMG cable，装置名为 Fang。发言人强调行为具有随机性：它可能触发拍照、录像、打开应用、生成代码、造成 denial of service（拒绝服务）级别的混乱，甚至在某些情况下触及 BIOS 层。这些名词的作用是标定风险边界，而非提供复现路径。演示的关键教训是：外部输入、设备权限、网络依赖、智能体自主决策和数据完整性风险可以串联成同一条业务风险链。

²²对应 00:50:15–00:53:18 的讨论。

²³对应 00:53:18–00:55:00 的讨论。

这个演示的教学意义在于，它把“聊天机器人回答错了”升级成“智能系统做错了”。一旦模型能调用工具，风险会从内容安全扩散到业务连续性、数据完整性、权限滥用和供应链污染。演示中还提到本地部署常被当成安全答案：企业把模型和数据都放在内网，以为 API 外发风险消失。可是如果输入设备、项目文件、插件、浏览器或工具链能向模型注入恶意上下文，本地环境同样会成为攻击面。

现场还回答了一个关键问题：该演示依赖网络，并非纯本地运行。这个细节很重要，因为它拆开了两类常被混在一起的风险：一类是数据是否离开组织边界，另一类是本地系统是否会被不可信输入和工具权限操控。即使企业改用私有部署或内网模型，项目文件、外设输入、浏览器上下文和插件仍然可能把恶意语义带进智能体。发言人最后用 ‘drop table’ 这类数据库灾难短语概括现实后果：真正危险的场景是业务数据完整性被破坏，且恢复成本极高。



图 22: 现场演示的受控环境：外部触发装置与笔记本交互，终端内容已模糊处理。此图用于说明智能体系统需要设备边界、工具权限和后端策略共同约束。²⁴

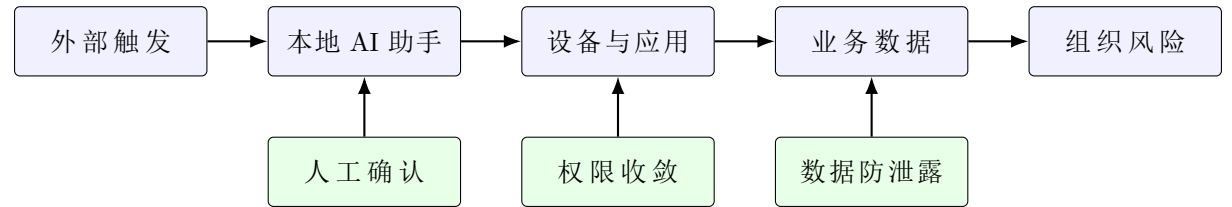


图 23: 本地智能体的业务风险链：外部输入经过模型和设备权限后，可能变成真实数据和运营风险。²⁵

²⁴视频时间：00:55:50–00:56:20；图中终端和潜在敏感内容已模糊处理。

²⁵对应 00:57:51–00:59:22 的讨论。

安全边界

本地运行、离线部署和私有模型只能降低某些数据外流路径，无法自动消除提示注入、工具越权、恶意文件、外设输入或日志缺失风险。真正的控制点仍然是权限隔离、工具网关、人工审批、敏感动作确认、完整审计和可回滚设计。

15.5 本章小结

本章从“首次越狱”的研究者体验转向智能体系统的工程风险。关键结论是：模型越狱本身只是起点，工具调用才把语义问题变成系统问题。可靠报告需要处理非确定性和幻觉，现场演示则提醒防御方关注输入来源、工具权限、执行隔离和业务后果。智能体能否安全有用，取决于模型之外的控制层是否足够坚硬。

16 总结：从“让模型拒绝”走向“让系统承受失败”

16.1 结尾讨论：危险输出验证的尴尬问题

视频最后一个实质性问题很尖锐：如果模型输出了危险类别内容，防御者如何判断这些内容是否真的“有用”？这涉及 AI 安全评估里一个尴尬事实。评估框架往往无法也不应真实验证危险行为，于是会使用关键词覆盖、步骤完整性、领域专家评审或安全替代指标来判断输出是否足够接近可操作指导。panelist 提到某类 jailbreak evaluation framework（越狱评估框架）会用关键词比例来粗略判断输出是否构成有效指导。

片中举例称，某些 Jailbreak Evaluation Framework 会用约 70%–80% 的关键词覆盖作为粗略信号。这个数字只说明评估框架如何做低成本筛查，不能代表真实世界的可操作性，也不能替代专家评审、受控验证和伤害最小化原则。换句话说，关键词覆盖像烟雾报警器：它能提示风险，需要后续确认，不能单独判断整栋楼的火情。

这类指标有价值，也有硬伤。关键词覆盖能让评估规模化，却可能把无害文本误判为危险，也可能漏掉语义等价的规避表达。专家评审更准确，却成本高、速度慢，还要处理伦理和法律边界。因此，最终 PDF 的安全立场应清楚：危险内容验证应服务于防御改进，测试材料要最小化伤害，报告应尽量使用安全替代目标、摘要化证据和受控环境。

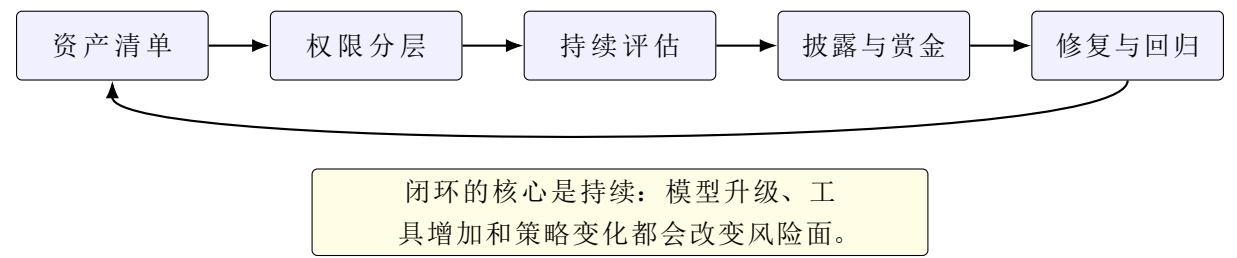


图 24: 收束路线图：资产、权限、评估、披露和回归测试形成闭环，才能跟上 AI 系统变化。²⁶

²⁶对应 00:59:22–01:00:16 的总结。

16.2 全片的风险压缩

把整场圆桌压缩成一个系统风险模型，可以写成：

$$R_{\text{AI system}} \approx C_{\text{model}} \times P_{\text{permissions}} \times E_{\text{exposure}} \times G_{\text{governance gap}}$$

其中 $R_{\text{AI system}}$ 是 AI 系统风险， C_{model} 是模型能力， $P_{\text{permissions}}$ 是系统授予模型或智能体的权限， E_{exposure} 是外部输入、插件、文件、浏览器、API 和 MCP 等入口暴露， $G_{\text{governance gap}}$ 是日志、监控、复现、审批、隔离和响应中的治理缺口。

这个公式的教学价值在于把“越狱”从单个提示扩展到完整系统。只降低拒答绕过率，仍可能在权限过大、工具直连、日志缺失和供应链不清时失败。反过来，即便模型偶尔误判，只要权限很小、动作需要确认、工具在沙箱中、敏感输出被过滤、所有调用可追踪，系统损失就能被限制。

重要提示

全片最重要的转向是：AI 安全不能停留在“让模型拒绝危险请求”。更稳健的目标是构建 failure-tolerant AI system（能承受失败的 AI 系统）：模型会犯错、分类器会漏报、用户会创造新语境、工具会扩大后果，因此架构必须默认局部失败会发生，并把失败限制在可观测、可阻断、可回滚的范围内。

16.3 防御路线图

第一，工程上应先做 threat modeling（威胁建模）。团队要列出模型能看到什么、能调用什么、能改变什么、输出会被谁消费、外部内容能从哪里进入。没有这张地图，提示注入和智能体越权只能靠事故暴露。

第二，做权限收缩。数据库、文件、邮件、浏览器、云资源和业务 API 都应按任务拆分权限。能读不代表能写，能总结不代表能执行，能建议不代表能提交。API key 要范围化、短期化、可吊销。

第三，做分层护栏。输入分类器、输出过滤、工具参数校验、后端拒绝策略、人工审批、沙箱、速率限制和日志应互相补位。任何一层都可能失败，多层组合才能降低总风险。

第四，做持续红队。模型版本、系统提示、工具链、数据源、插件、MCP 服务和业务流程都会变化。一次评估只能覆盖当时状态。持续测试要吸收传统安全人员、语言和写作背景成员、业务专家以及真实用户反馈。

第五，做可复现报告。AI 漏洞报告需要记录模型版本、时间、上下文、系统配置、工具权限、消息 ID、输出证据和重复试验范围。对非确定性结果，应报告概率和条件，避免把偶发输出包装成稳定结论。

知识点

可以把 AI 防御类比为飞机安全体系。与门锁安全相比，飞机安全思维会假设部件老化、传感器误读、人员犯错，于是依靠冗余、检查单、黑匣子、隔离舱和事故复盘。AI 系统也需要这种工程韧性。

16.4 本章小结

圆桌最后回到一个朴素问题：AI 安全评估如何证明危险输出真的危险？回答并不完美，关键词、专家评审和替代指标都只是受限工具。全片更大的结论是，越狱难题会随着能力、权限和工具接入继续扩张。防御方需要从模型拒答转向系统韧性：威胁建模、最小权限、工具隔离、后端策略、日志审计、复现协议和多样化红队共同构成防线。模型可以失败，系统不能把一次失败直接放大成不可逆业务后果。

A 资料来源与制作说明

- 视频来源：<https://www.youtube.com/watch?v=yxqGAtUR8fY>，频道为 Bug Bounty DEF-CON，发布日期为 2026-06-01。
- 字幕来源：本地下载的英文字幕文件 `source/source.en.vtt` 与清洗后的 `source/transcript_timecoded.md`。
- 图像来源：视频抽帧、封面转换和为解释概念生成的 TikZ 图。涉及现场演示的终端图像已做模糊处理。
- 安全处理：危险样例被抽象成风险类别，讲义保留防御含义、工程边界和披露流程，避免给出可复现攻击载荷。